25900051

MAHATMA GANDHI UNIVERSITY, KOTTAYAM
MGU-UGP (HONOURS) REGULAR EXAMINATION MARCH 2025
SECOND SEMESTER
Discipline Specific Core Course (DSC) - MG2DSCCFS100 – INTRODUCTION TO ETHICAL HACKING AND TOOLS
(2024 ADMISSION ONWARDS)

Duration: 1.5 Hours **Maximum Marks: 50**

Remember(K), Understand(U), Apply(A), Analyse(An), Evaluate(E), Create(C), Skill(S), Interest(I)and Appreciation(Ap)

Part A
Short Answer Type Questions
Answer any 10 *questions*
Each question carries ***1*** *marks*

1. Describe about the purpose of privilege escalation in post-exploitation. [U] / [CO1]

The purpose of privilege escalation in post-exploitation is to gain higher-level access—typically administrative or root privileges—on a compromised system, allowing the attacker to execute more powerful commands, access sensitive data, and maintain persistent control.

2. Explain about the role of documentation in incident response. [U] / [CO1]

Documentation plays a crucial role in incident response by providing a clear, chronological record of actions taken, decisions made, and evidence collected during an incident. It ensures accountability, supports legal and compliance requirements, and helps improve future response efforts through post-incident analysis and lessons learned.

3. Discuss how vulnerability analysis can be used to maintain the security of an organization's systems and data. [U] / [CO1]

Vulnerability analysis helps maintain the security of an organization's systems and data by identifying, evaluating, and prioritizing security weaknesses before they can be exploited by attackers. By regularly scanning systems, software, and networks for vulnerabilities, organizations can proactively apply patches, reconfigure insecure settings, and implement necessary security controls to reduce risk, ensure compliance, and protect critical assets from potential threats.

4. Explain the role of white hat hackers. [U] / [CO1]

White hat hackers, also known as ethical hackers, play a vital role in cybersecurity by legally testing and assessing systems for vulnerabilities to help organizations strengthen their defenses. They use the same techniques as malicious hackers but with permission and the goal of identifying and fixing security flaws before they can be exploited.

5. Explain about Penetration testing. [U] / [CO1]

Penetration testing, or ethical hacking, is a simulated cyberattack performed by security professionals to identify and exploit vulnerabilities in an organization's systems, networks, or applications. Its purpose is to evaluate the effectiveness of security measures, uncover potential entry points for attackers, and provide actionable insights to improve overall security posture.

6. Compare Vulnerability Vs Threat Vs Risk. [U] / [CO1, CO2]

Vulnerability: A weakness or flaw in a system, software, or process that could be exploited (e.g., outdated software, misconfigured firewall).

- **Threat**: Any potential danger that could exploit a vulnerability to cause harm (e.g., malware, hackers, natural disasters).
- **Risk**: The potential impact or loss when a threat successfully exploits a vulnerability (e.g., data breach resulting in financial and reputational damage).

7. Explain buffer overflow. **[U] / [CO1, CO2]**

A **buffer overflow** occurs when a program writes more data to a buffer (a temporary storage area in memory) than it can hold, causing the excess data to overwrite adjacent memory. This can lead to unexpected behavior, crashes, or security vulnerabilities, as attackers can exploit it to inject malicious code and gain unauthorized access or control over a system.

8. Indicate how DoS differs from DDoS. **[U] / [CO2]**

A **DoS (Denial of Service)** attack involves a single source overwhelming a system or network with traffic or requests to make it unavailable to users. In contrast, a **DDoS (Distributed Denial of Service)** attack uses multiple compromised systems (often part of a botnet) to launch a coordinated attack, making it harder to block and more damaging due to the scale.

9. Identify any one input validation attack. **[U] / [CO1, CO2]**

SQL Injection – Injecting malicious SQL commands to manipulate databases.

- **Cross-Site Scripting (XSS)** – Inserting malicious scripts into web pages viewed by other users.
- **Command Injection** – Executing arbitrary system commands through improperly validated input.
- **Buffer Overflow** – Inputting excessive data to overwrite memory and execute code.
- **Directory Traversal** – Manipulating file paths to access restricted directories or files.
- **Format String Attack** – Exploiting format string vulnerabilities to read or write memory.

10. Describe HTTP. **[U] / [CO1]**

HTTP (Hypertext Transfer Protocol). It is a protocol used for transferring hypertext (web pages) and other resources between a client (like a web browser) and a server.

11. Compare NIDS and HIDS. **[An] / [CO3]**

NIDS (Network Intrusion Detection System) monitors network traffic to detect suspicious activity across multiple devices, focusing on network-level attacks. **HIDS (Host Intrusion Detection System)**, on the other hand, is installed on individual devices to monitor system-level activities, detecting threats specific to the host.

12. Explain about the datalink layer. **[U] / [CO1]**

The **Data Link Layer** (Layer 2) of the OSI model is responsible for establishing, maintaining, and terminating communication links between devices on the same network. It handles the framing, addressing (MAC addresses), error detection, and flow control for data transmission between devices on a local area network (LAN) or other network segments.

[1x10 = 10]

Part B
Short Essay Type Questions
Answer any 4 questions
Each question carries **5** marks

13. Explain the key provisions of the IT Act 200 **[U] / [CO1]**

The key provisions of the **IT Act 2000** (Information Technology Act, 2000) in India include:

Legal Recognition of Electronic Records, Digital Signatures, Cybercrimes, Electronic Governance, Privacy and Data Protection, Adjudication and Penalties, Certifying Authorities, Cyber Appellate Tribunal.

for correct answer- 5 marks

14. Explain about reconnaissance. [U] / [CO1]

Reconnaissance is the first phase in the process of cyberattacks or penetration testing, where attackers or security professionals gather crucial information about a target system or network. The goal of reconnaissance is to collect as much intelligence as possible to identify vulnerabilities that can later be exploited .

Reconnaissance can be divided into two main types:Active Reconnaissance, Passive Reconnaissance:

Explanation of Reconnaissance – 2 marks

for writing the name of its types – 1 mark

explanation of its types -2 marks

15. Discuss shortly about: a) Password attacks b) Social engineering attacks.[U] / [CO1, CO2]

Password attacks involve methods used by attackers to gain unauthorized access to systems or accounts by cracking or bypassing passwords. Common types include brute-force attacks (trying all possible password combinations), dictionary attacks (using a list of common passwords), and credential stuffing (using previously leaked username-password pairs). The goal is to exploit weak or reused passwords to compromise user accounts and systems.

Social engineering attacks manipulate individuals into divulging confidential information or performing actions that compromise security. Common types include phishing (fraudulent emails or websites tricking users into revealing personal information), pretexting (creating a fabricated scenario to steal information), and baiting (offering something enticing to lure victims into compromising security). These attacks exploit human psychology rather than technical vulnerabilities.

password attack explanation 2.5 marks
social engineering 2.5 marks

16. Discuss about IP spoofing. [U] / [CO1, CO2]

IP Spoofing is a technique used in cyberattacks where an attacker falsifies the source IP address in the header of an IP packet to make it appear as though the packet is coming from a trusted or legitimate source. This technique is commonly used to bypass security measures, mislead systems, and conceal the identity of the attacker

explanation -3 marks
types of attack or working – 2 marks

17. Simplify how application proxy firewall work. [An] / [CO3]

An **Application Proxy Firewall** works by acting as an intermediary between a user and the application they are trying to access

explanation – 2 marks
working – 3 marks

18. Discuss about the importance of website protection. [U] / [CO1]

Website protection is crucial for maintaining the security, integrity, and availability of a website, as it helps safeguard both the website's data and the users interacting with it.

Importance: Preventing Cyberattacks, Safeguarding User Data, Maintaining Trust and Reputation, Compliance with Legal and Regulatory Standards, Ensuring Business Continuity, Preventing SEO Damage

give 5 marks for correct answer.

[5x4 = 20]

Part C
Essay Type Questions
Answer any 2 questions
Each question carries 1**0** marks

19. Describe the differences between Gray Hat Hackers and Black Hat Hackers, including their motivations, tactics, and impact on organizations. [U] / [CO1]

Gray Hat hackers find vulnerabilities without permission but typically do not have malicious intent, often reporting the issues they discover, although their actions may still be legally questionable. In contrast, Black Hat hackers exploit vulnerabilities for malicious purposes, such as personal gain or causing harm, and engage in illegal activities like data theft or deploying malware.

key difference between gray hat hackers and black hat hackers, their motivation and tactics, impact on organization – 10 marks

20. Discuss in detail about Phishing attacks. [U] / [CO1, CO2]

Phishing is one of the most common and deceptive types of cyberattacks used by hackers to gain unauthorized access to sensitive information such as login credentials, financial data, or personal identification details. These attacks exploit human vulnerability, typically using fraudulent emails, websites, or messages that appear to come from legitimate sources.

Explanation, types of phishing attacks, its working and prevention -10 marks

21. Classify different types of firewall. [U] / [CO1]

Firewalls are essential components of network security, designed to monitor and control incoming and outgoing network traffic based on predetermined security rules. They act as a barrier between trusted and untrusted networks, ensuring that unauthorized access is prevented while allowing legitimate communication to pass through. Firewalls can be classified into several types based on their functionality, configuration, and the layer of the OSI model they operate on.

Packet Filter Firewalls, Packet Inspection Firewalls, Application Proxy Firewalls,Hardware Firewalls, Software Firewalls – 10 marks

[10x2 = 20]